Mock Security Audit:

Scenario:

Botium Toys is a small U.S. business that develops and sells toys. The business has a single physical location, which serves as their main office, a storefront, and warehouse for their products. However, Botium Toy's online presence has grown, attracting customers in the U.S. and abroad. As a result, their information technology (IT) department is under increasing pressure to support their online market worldwide.

The manager of the IT department has decided that an internal IT audit needs to be conducted. She's worried about maintaining compliance and business operations as the company grows without a clear plan. She believes an internal audit can help better secure the company's infrastructure and help them identify and mitigate potential risks, threats, or vulnerabilities to critical assets. The manager is also interested in ensuring that they comply with regulations related to internally processing and accepting online payments and conducting business in the European Union (E.U.).

The IT manager starts by implementing the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF), establishing an audit scope and goals, listing assets currently managed by the IT department, and completing a risk assessment. The goal of the audit is to provide an overview of the risks and/or fines that the company might experience due to the current state of their security posture.

Summary:

The internal IT audit of Botium Toys identified several security risks relating to inadequate asset management, missing security controls and potential compliance gaps. The overall risk score was assessed as 8 out of 10, indicating a relatively high level of risk to the organisation's assets and business operations.

The audit also highlighted the need to review compliance with PCI DSS requirements for payment card data and relevant SOC reporting criteria. By addressing these weaknesses, maintaining existing controls and conducting regular reviews, Botium Toys can reduce security risks, improve compliance and support the safe growth of its online business.

Scope:

The internal IT audit will assess the following assets:

- Employee equipment and devices, their internal network, their systems.
- Storefront products available for retail sale on site and online
- Management of systems, software, and services.
- Internet access
- Internal network
- Data retention and storage
- Legacy system maintenance

The internal IT audit will identify:

- Existing controls, procedures and system protocols

Goals:

The internal IT audit will:

- Adhere to the NIST Cybersecurity Framework (CSF)
- Establish policies and procedures to ensure compliance with regulations relating to internally processing and accepting online payments and conducting business in the European Union (E.U.).
- Fortify system controls

Risk assessment

Risk description

Currently, there is inadequate management of assets. Additionally, Botium Toys does not have all of the proper controls in place and may not be fully compliant with U.S. and international regulations and standards.

Control best practices

The first of the five functions of the NIST CSF is Identify. Botium Toys will need to dedicate resources to identify assets so they can appropriately manage them. Additionally, they will need to classify existing assets and determine the impact of the loss of existing assets, including systems, on business continuity.

Risk score

On a scale of 1 to 10, the risk score is 8, which is fairly high. This is due to a lack of controls and adherence to compliance best practices.

Additional comments

The potential impact from the loss of an asset is rated as medium, because the IT

department does not know which assets would be at risk. The risk to assets or fines from governing bodies is high because Botium Toys does not have all of the necessary controls in place and is not fully adhering to best practices related to compliance regulations that keep critical data private/secure.

Controls Assessment:

Administrative Controls			
Control Name	**Control type and explanation**	**Needs to be implemented (X)**	**Priority**
Least Privilege:	Preventative: Reduce risk and overall impact of malicious insider or compromised accounts.	X	High
Disaster recovery plans	Corrective: Provide business continuity	X	High
Password policies	Preventative: Reduce likelihood of account compromise through brute force or dictionary attack techniques	X	Medium: (Current pp's exist but are not in compliance with current complexity requirements)
Separation of duties	Preventative: Reduce risk and overall impact of malicious insider or compromised accounts	X	High

Technical Controls			
Control Name	**Control type and explanation**	**Needs to be implemented (X)**	**Priority**

Firewall	Preventative: To filter unwanted or malicious traffic from entering the network		
IDS/IPS	Detective: To detect and prevent anomalous traffic that matches a signature or rule	X	High
Encryption	Preventive: Provide confidentiality to sensitive information	X	High
Backups	Corrective: Restore/recover from an event	X	High
Password management	Preventative: Reduce password fatigue	X	Medium
Antivirus (AV) software	Preventive: Detect and quarantine known threats		
Manual monitoring, maintenance, and intervention	Preventative: Necessary to identify and manage threats, risks, or vulnerabilities to out-of-date systems	X	Medium: (There is no regular schedule in place for these tasks and intervention methods are unclear.)

Physical Controls			
Control Name	**Control type and**	**Needs to be**	**Priority**

	explanation	implemented (X)	
Closed-circuit television (CCTV)	Preventative/Deterrent: It's presence can reduce risk of certain types of events from occurring, and can be used after an event to inform on event conditions		
Locks	Deterrent/Preventative: Bolster integrity by deterring and preventing unauthorized personnel, individuals from physically accessing assets		
Fire detection and prevention (fire alarm, sprinkler system, etc.)	Detective/Preventative: Detect fire in physical location and prevent damage to physical assets such as inventory, servers, etc.		

Compliance Checklist:

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☑	Only authorized users have access to customers' credit card information.
☑	☐	Credit card information is stored, accepted, processed, and

transmitted internally, in a secure environment.

☐	☑	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☑	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☑	☐	E.U. customers' data is kept private/secured.
☑	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☑	☐	Ensure data is properly classified and inventoried.
☑	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☑	☐	User access policies are established.
☐	☑	Sensitive data (PII/SPII) is confidential/private.
☑	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☑	☐	Data is available to individuals authorized to access it.

Recommendations:

Controls

1. **Improve asset management:** Create a complete inventory of hardware, software, systems and data. Classify assets according to their sensitivity and business importance to identify critical assets and prioritise protection.

2. **Strengthen access controls:** Implement the principle of least privilege and separation of duties to ensure employees only access the systems and information necessary for their roles. Review user permissions regularly.
3. **Improve password security:** Update password policies to meet current security requirements and introduce password management tools and multi-factor authentication (MFA) to reduce the risk of account compromise.
4. **Strengthen network and data security:** Implement intrusion detection and prevention systems (IDS/IPS) and encrypt sensitive data at rest and in transit to protect customer information and payment transactions.
5. **Implement backups and disaster recovery:** Establish regular, secure backups and create a disaster recovery plan to restore critical systems and maintain business continuity following a cyberattack, system failure or disaster.
6. **Improve system maintenance:** Establish a regular schedule for software updates, security patches and vulnerability assessments. Clarify maintenance responsibilities to ensure outdated systems and emerging threats are addressed promptly.
7. **Maintain existing security controls:** Regularly review firewall configurations, update antivirus software and test physical security measures, including locks, CCTV and fire detection systems, to ensure they remain effective.
8. **Ensure regulatory compliance:** Review practices against PCI DSS requirements for payment card data and GDPR requirements for personal data belonging to EU customers. Establish appropriate data protection procedures and a process for reporting eligible personal data breaches to the relevant supervisory authority within 72 hours where GDPR requires it.
9. **Improve employee security awareness:** Provide regular training on phishing, social engineering, password security and the safe handling of sensitive information to reduce human error and data breaches.
10. **Conduct regular internal audits:** Use the NIST Cybersecurity Framework to review existing controls, identify compliance gaps and assess whether corrective actions are effective as the business grows.

PCI DSS Compliance Recommendations

- **Restrict access to credit card information:** Implement role-based access controls and the principle of least privilege to ensure that only authorised employees can access customers' credit card information.
- **Encrypt payment data:** Implement encryption for credit card data both at rest and in transit to protect sensitive information during storage and transmission.
- **Strengthen password management:** Enforce secure password policies and introduce password management tools and multi-factor authentication (MFA) to reduce the risk of unauthorised access to payment systems.

These measures will help Botium Toys strengthen payment data security and align its practices with applicable PCI DSS requirements.

SOC 1 and SOC 2 Compliance Recommendation

Implement appropriate data protection controls to maintain the confidentiality and privacy of personally identifiable information (PII) and sensitive personally identifiable information

(SPII). These should include encrypting sensitive data at rest and in transit, restricting access to authorised personnel through the principle of least privilege, and establishing clear data handling and retention policies. Regularly review these controls to help protect sensitive information from unauthorised access or disclosure and strengthen the organisation's security posture.